

Informe de Evaluación de Controles

ISO/IEC 27001:2013 — Anexo A

114 Controles · 14 Dominios de Seguridad

Evaluación de cumplimiento y estado de implementación

Norma de referencia:	ISO/IEC 27001:2013 e ISO/IEC 27002:2013
Código documento:	INF-SGSI-2023-047
Versión:	3.2
Fecha de evaluación:	28 de noviembre de 2023
Próxima revisión:	28 de noviembre de 2024
Responsable:	Dirección de Gestión de Riesgos y Cumplimiento
Clasificación:	USO INTERNO — CONFIDENCIAL

1. Introducción y marco normativo

El presente informe documenta la evaluación del estado de implementación de los controles del Anexo A de la norma **ISO/IEC 27001:2013**, complementada con la guía de implementación de **ISO/IEC 27002:2013**. La evaluación cubre los **114 controles** agrupados en **14 dominios** (A.5 a A.18) y fue realizada en noviembre de 2023.

La metodología empleada asigna a cada control un estado de implementación, un nivel de madurez (escala 0–5) y un nivel de riesgo residual, conforme a los criterios definidos en el procedimiento interno PRO-AUD-2013-001 aprobado en 2014 y revisado en 2019.

1.1 Resumen ejecutivo por dominio

Dominio	Nombre del dominio	Controles	Implementado	Parcial	No aplicable
A.5	Políticas de seguridad de la información	2	2	0	0
A.6	Organización de la seguridad de la informació	7	4	2	1
A.7	Seguridad relativa a los recursos humanos	6	4	2	0
A.8	Gestión de activos	10	5	3	2
A.9	Control de acceso	14	9	4	1
A.10	Criptografía	2	1	1	0
A.11	Seguridad física y del entorno	15	11	3	0
A.12	Seguridad de las operaciones	14	7	6	1
A.13	Seguridad de las comunicaciones	7	5	2	0
A.14	Adquisición, desarrollo y mantenimiento de si	13	1	6	6
A.15	Relaciones con proveedores	5	2	2	1
A.16	Gestión de incidentes de seguridad de la info	7	3	2	2
A.17	Aspectos de seguridad de la información en la	4	0	3	1
A.18	Cumplimiento	8	3	3	2

2. Detalle de controles por dominio

A continuación se presenta el detalle de evaluación de cada uno de los 114 controles del Anexo A de la norma ISO/IEC 27001:2013, organizados por dominio.

A.5 Políticas de seguridad de la información — 2 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.5.1.1	Políticas para la seguridad de la información	Implementado	4	Bajo	CISO
A.5.1.2	Revisión de las políticas de seguridad de la información	Implementado	3	Medio	CISO

A.6 Organización de la seguridad de la información — 7 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.6.1.1	Roles y responsabilidades para la seguridad de la información	Implementado	3	Medio	TI / RRHH
A.6.1.2	Segregación de funciones	Parcialmente implementado	2	Alto	TI
A.6.1.3	Contacto con las autoridades	Implementado	4	Bajo	Legal
A.6.1.4	Contacto con grupos de interés especial	No implementado	1	Alto	CISO
A.6.1.5	Seguridad de la información en la gestión de proyectos	Parcialmente implementado	2	Medio	PMO
A.6.2.1	Política para dispositivos móviles	Implementado	3	Medio	TI
A.6.2.2	Teletrabajo	Implementado	4	Bajo	TI

A.7 Seguridad relativa a los recursos humanos — 6 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.7.1.1	Investigación de antecedentes	Implementado	4	Bajo	RRHH
A.7.1.2	Términos y condiciones de contratación	Implementado	4	Bajo	RRHH
A.7.2.1	Responsabilidades de gestión	Parcialmente implementado	2	Alto	RRHH
A.7.2.2	Concienciación, educación y capacitación en SI	Implementado	4	Bajo	RRHH
A.7.2.3	Proceso disciplinario	Implementado	3	Medio	RRHH
A.7.3.1	Responsabilidades ante la finalización o cambio	Parcialmente implementado	2	Medio	RRHH

A.8 Gestión de activos — 10 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.8.1.1	Inventario de activos	Implementado	3	Medio	TI
A.8.1.2	Propiedad de los activos	Implementado	3	Medio	TI
A.8.1.3	Uso aceptable de los activos	Implementado	4	Bajo	Legal
A.8.1.4	Devolución de los activos	Parcialmente implementado	2	Medio	RRHH

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.8.2.1	Clasificación de la información	Implementado	3	Medio	CISO
A.8.2.2	Etiquetado de la información	No implementado	1	Alto	CISO
A.8.2.3	Manipulación de activos	Parcialmente implementado	2	Medio	TI
A.8.3.1	Gestión de medios extraíbles	Parcialmente implementado	2	Alto	TI
A.8.3.2	Eliminación de medios	Implementado	3	Medio	TI
A.8.3.3	Transferencia de medios físicos	No implementado	0	Crítico	Operaciones

A.9 Control de acceso — 14 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.9.1.1	Política de control de acceso	Implementado	4	Bajo	TI
A.9.1.2	Acceso a redes y servicios de red	Implementado	3	Medio	TI
A.9.2.1	Registro y baja de usuarios	Implementado	4	Bajo	TI
A.9.2.2	Provisión de acceso a usuarios	Implementado	3	Medio	TI
A.9.2.3	Gestión de derechos de acceso privilegiado	Parcialmente implementado	2	Alto	TI
A.9.2.4	Gestión de información de autenticación secreta	Parcialmente implementado	2	Alto	TI
A.9.2.5	Revisión de derechos de acceso de usuarios	No implementado	1	Alto	TI
A.9.2.6	Retirada o reasignación de derechos de acceso	Implementado	3	Medio	TI
A.9.3.1	Uso de información de autenticación secreta	Implementado	4	Bajo	Todos
A.9.4.1	Restricción de acceso a la información	Implementado	3	Medio	TI
A.9.4.2	Procedimientos seguros de inicio de sesión	Implementado	4	Bajo	TI
A.9.4.3	Sistema de gestión de contraseñas	Implementado	4	Bajo	TI
A.9.4.4	Uso de herramientas de administración de sistemas	Parcialmente implementado	2	Medio	TI
A.9.4.5	Control de acceso al código fuente	Parcialmente implementado	2	Medio	Desarrollo

A.10 Criptografía — 2 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.10.1.1	Política de uso de controles criptográficos	Implementado	3	Medio	TI
A.10.1.2	Gestión de claves	Parcialmente implementado	2	Alto	TI

A.11 Seguridad física y del entorno — 15 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.11.1.1	Perímetro de seguridad física	Implementado	4	Bajo	Operaciones
A.11.1.2	Controles de acceso físico	Implementado	4	Bajo	Operaciones
A.11.1.3	Seguridad de oficinas, despachos y recursos	Implementado	3	Medio	Operaciones

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.11.1.4	Protección contra amenazas externas y ambientales	Implementado	4	Bajo	Operaciones
A.11.1.5	El trabajo en áreas seguras	Implementado	3	Medio	Operaciones
A.11.1.6	Áreas de carga y descarga	No aplica	—	N/A	Operaciones
A.11.2.1	Emplazamiento y protección de equipos	Implementado	4	Bajo	TI
A.11.2.2	Servicios de suministro	Implementado	3	Medio	Operaciones
A.11.2.3	Seguridad del cableado	Implementado	3	Medio	TI
A.11.2.4	Mantenimiento de los equipos	Implementado	3	Medio	TI
A.11.2.5	Retirada de activos	Implementado	4	Bajo	TI
A.11.2.6	Seguridad de los equipos fuera de las instalaciones	Parcialmente implementado	2	Medio	TI
A.11.2.7	Reutilización o eliminación segura de equipos	Implementado	3	Medio	TI
A.11.2.8	Equipo de usuario desatendido	Parcialmente implementado	2	Medio	Todos
A.11.2.9	Política de puesto de trabajo despejado y pantalla limpia	Parcialmente implementado	2	Medio	Todos

A.12 Seguridad de las operaciones — 14 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.12.1.1	Procedimientos de operación documentados	Implementado	4	Bajo	TI
A.12.1.2	Gestión de cambios	Implementado	3	Medio	TI
A.12.1.3	Gestión de capacidades	Parcialmente implementado	2	Medio	TI
A.12.1.4	Separación de los entornos de desarrollo, prueba y producción	Implementado	3	Medio	Desarrollo
A.12.2.1	Controles contra el código malicioso	Implementado	4	Bajo	TI
A.12.3.1	Copias de seguridad de la información	Implementado	3	Medio	TI
A.12.4.1	Registro de eventos	Parcialmente implementado	2	Alto	TI
A.12.4.2	Protección de la información de registro	Parcialmente implementado	2	Alto	TI
A.12.4.3	Registros de administración y operación	Parcialmente implementado	2	Medio	TI
A.12.4.4	Sincronización del reloj	Implementado	3	Medio	TI
A.12.5.1	Instalación del software en sistemas en producción	Implementado	3	Medio	TI
A.12.6.1	Gestión de las vulnerabilidades técnicas	Parcialmente implementado	2	Alto	TI
A.12.6.2	Restricciones en la instalación de software	No implementado	1	Alto	TI
A.12.7.1	Controles de auditoría de sistemas de información	Parcialmente implementado	2	Medio	Auditoría

A.13 Seguridad de las comunicaciones — 7 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.13.1.1	Controles de red	Implementado	4	Bajo	TI
A.13.1.2	Seguridad de los servicios de red	Implementado	3	Medio	TI
A.13.1.3	Segregación en redes	Implementado	3	Medio	TI
A.13.2.1	Políticas y procedimientos de transferencia de información	Parcialmente implementado	2	Medio	Legal
A.13.2.2	Acuerdos de transferencia de información	Parcialmente implementado	2	Medio	Legal
A.13.2.3	Mensajería electrónica	Implementado	3	Medio	TI
A.13.2.4	Acuerdos de confidencialidad o no divulgación	Implementado	4	Bajo	Legal

A.14 Adquisición, desarrollo y mantenimiento de sistemas — 13 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.14.1.1	Análisis y especificación de requisitos de seguridad	Parcialmente implementado	2	Alto	Desarrollo
A.14.1.2	Seguridad de servicios de aplicaciones en redes públicas	No implementado	1	Crítico	Desarrollo
A.14.1.3	Protección de las transacciones de servicios de aplicaciones	No implementado	0	Crítico	Desarrollo
A.14.2.1	Política de desarrollo seguro	Parcialmente implementado	2	Alto	Desarrollo
A.14.2.2	Procedimiento de control de cambios en sistemas	Implementado	3	Medio	Desarrollo
A.14.2.3	Revisión técnica de aplicaciones tras cambios en la plataforma	No implementado	1	Alto	Desarrollo
A.14.2.4	Restricciones en los cambios a los paquetes de software	Parcialmente implementado	2	Medio	Desarrollo
A.14.2.5	Principios de ingeniería de sistemas seguros	No implementado	1	Alto	Desarrollo
A.14.2.6	Entorno de desarrollo seguro	Parcialmente implementado	2	Alto	Desarrollo
A.14.2.7	Desarrollo externalizado	No implementado	1	Alto	Desarrollo
A.14.2.8	Pruebas de seguridad del sistema	Parcialmente implementado	2	Alto	Desarrollo
A.14.2.9	Pruebas de aceptación del sistema	Parcialmente implementado	2	Medio	Desarrollo
A.14.3.1	Protección de los datos de prueba	No implementado	1	Alto	Desarrollo

A.15 Relaciones con proveedores — 5 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.15.1.1	Política de seguridad de la información en las relaciones con los proveedores	Implementado	3	Medio	Legal
A.15.1.2	Requisitos de seguridad en contratos con terceros	Implementado	3	Medio	Legal
A.15.1.3	Cadena de suministro de tecnología de la información y de las comunicaciones	No implementado	1	Alto	Legal
A.15.2.1	Control y revisión de la provisión de servicios del proveedor	Parcialmente implementado	2	Medio	Operaciones

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.15.2.2	Gestión de cambios en la provisión del servicio del proveedor	Parcialmente implementado	2	Medio	Operaciones

A.16 Gestión de incidentes de seguridad de la información — 7 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.16.1.1	Responsabilidades y procedimientos	Implementado	3	Medio	TI
A.16.1.2	Notificación de los eventos de seguridad de la información	Implementado	3	Medio	Todos
A.16.1.3	Notificación de puntos débiles de seguridad	Parcialmente implementado	2	Medio	Todos
A.16.1.4	Evaluación y decisión sobre los eventos de SI	Parcialmente implementado	2	Alto	TI
A.16.1.5	Respuesta a incidentes de seguridad de la información	Implementado	3	Medio	TI
A.16.1.6	Aprendizaje de los incidentes de seguridad de la información	No implementado	1	Alto	TI
A.16.1.7	Recopilación de evidencias	No implementado	1	Alto	TI

A.17 Aspectos de seguridad de la información en la gestión de la continuidad del negocio — 4 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.17.1.1	Planificación de la continuidad de la seguridad de la información	Parcialmente implementado	2	Alto	Continuidad de Negocio
A.17.1.2	Implementación de la continuidad de la SI	Parcialmente implementado	2	Alto	Continuidad de Negocio
A.17.1.3	Verificación, revisión y evaluación de la continuidad de la SI	No implementado	1	Crítico	Continuidad de Negocio
A.17.2.1	Disponibilidad de instalaciones de procesamiento de información	Parcialmente implementado	2	Alto	TI

A.18 Cumplimiento — 8 controles

Código	Control (ISO 27001:2013)	Estado	Madurez	Riesgo	Responsable
A.18.1.1	Identificación de legislación aplicable y requisitos contractuales	Implementado	4	Bajo	Legal
A.18.1.2	Derechos de propiedad intelectual	Implementado	3	Medio	Legal
A.18.1.3	Protección de los registros de la organización	Implementado	3	Medio	Legal
A.18.1.4	Privacidad y protección de datos de carácter personal	Parcialmente implementado	2	Alto	Legal
A.18.1.5	Regulación de los controles criptográficos	No implementado	1	Alto	TI
A.18.2.1	Revisión independiente de la seguridad de la información	Parcialmente implementado	2	Alto	Auditoría
A.18.2.2	Cumplimiento de las políticas y normas de seguridad	Parcialmente implementado	2	Medio	CISO
A.18.2.3	Revisión del cumplimiento técnico	No implementado	1	Alto	TI

3. Controles con riesgo alto o crítico

Los siguientes controles de la norma ISO/IEC 27001:2013 presentan riesgo alto o crítico y requieren atención prioritaria en el plan de tratamiento.

Código	Control (ISO/IEC 27001:2013)	Dominio	Estado	Ref.	Riesgo	Responsable
A.6.1.2	Segregación de funciones	A.6	Parcialmente implementado	2	Alto	TI
A.6.1.4	Contacto con grupos de interés especial	A.6	No implementado	1	Alto	CISO
A.7.2.1	Responsabilidades de gestión	A.7	Parcialmente implementado	2	Alto	RRHH
A.8.2.2	Etiquetado de la información	A.8	No implementado	1	Alto	CISO
A.8.3.1	Gestión de medios extraíbles	A.8	Parcialmente implementado	2	Alto	TI
A.8.3.3	Transferencia de medios físicos	A.8	No implementado	—	Crítico	Operaciones
A.9.2.3	Gestión de derechos de acceso privilegiado	A.9	Parcialmente implementado	2	Alto	TI
A.9.2.4	Gestión de información de autenticación secreta	A.9	Parcialmente implementado	2	Alto	TI
A.9.2.5	Revisión de derechos de acceso de usuarios	A.9	No implementado	1	Alto	TI
A.10.1.2	Gestión de claves	A.10	Parcialmente implementado	2	Alto	TI
A.12.4.1	Registro de eventos	A.12	Parcialmente implementado	2	Alto	TI
A.12.4.2	Protección de la información de registro	A.12	Parcialmente implementado	2	Alto	TI
A.12.6.1	Gestión de las vulnerabilidades técnicas	A.12	Parcialmente implementado	2	Alto	TI
A.12.6.2	Restricciones en la instalación de software	A.12	No implementado	1	Alto	TI
A.14.1.1	Análisis y especificación de requisitos de seguridad	A.14	Parcialmente implementado	2	Alto	Desarrollo
A.14.1.2	Seguridad de servicios de aplicaciones en redes públicas	A.14	No implementado	1	Crítico	Desarrollo
A.14.1.3	Protección de las transacciones de servicios de aplicaciones	A.14	No implementado	—	Crítico	Desarrollo
A.14.2.1	Política de desarrollo seguro	A.14	Parcialmente implementado	2	Alto	Desarrollo
A.14.2.3	Revisión técnica de aplicaciones tras cambios en la plataforma	A.14	No implementado	1	Alto	Desarrollo
A.14.2.5	Principios de ingeniería de sistemas seguros	A.14	No implementado	1	Alto	Desarrollo
A.14.2.6	Entorno de desarrollo seguro	A.14	Parcialmente implementado	2	Alto	Desarrollo

Control	Control ISO/IEC 27001:2013	Dominio	Estado	WOT	Riesgo	Responsable
A.14.2.7	Desarrollo externalizado	A.14	No implementado	1	Alto	Desarrollo
A.14.2.8	Pruebas de seguridad del sistema	A.14	Parcialmente implementado	2	Alto	Desarrollo
A.14.3.1	Protección de los datos de prueba	A.14	No implementado	1	Alto	Desarrollo
A.15.1.3	Cadena de suministro de tecnología de la información y de las comunicaciones	A.15	No implementado	1	Alto	Legal
A.16.1.4	Evaluación y decisión sobre los eventos de SI	A.16	Parcialmente implementado	2	Alto	TI
A.16.1.6	Aprendizaje de los incidentes de seguridad de la información	A.16	No implementado	1	Alto	TI
A.16.1.7	Recopilación de evidencias	A.16	No implementado	1	Alto	TI
A.17.1.1	Planificación de la continuidad de la seguridad de la información	A.17	Parcialmente implementado	2	Alto	Continuidad de Negocio
A.17.1.2	Implementación de la continuidad de la SI	A.17	Parcialmente implementado	2	Alto	Continuidad de Negocio
A.17.1.3	Verificación, revisión y evaluación de la continuidad de la SI	A.17	No implementado	1	Crítico	Continuidad de Negocio
A.17.2.1	Disponibilidad de instalaciones de procesamiento de información	A.17	Parcialmente implementado	2	Alto	TI
A.18.1.4	Privacidad y protección de datos de carácter personal	A.18	Parcialmente implementado	2	Alto	Legal
A.18.1.5	Regulación de los controles criptográficos	A.18	No implementado	1	Alto	TI
A.18.2.1	Revisión independiente de la seguridad de la información	A.18	Parcialmente implementado	2	Alto	Auditoría
A.18.2.3	Revisión del cumplimiento técnico	A.18	No implementado	1	Alto	TI

4. Vigencia del marco normativo y próximas acciones

Este informe ha sido elaborado conforme a los requisitos de la norma **ISO/IEC 27001:2013**, que constituye el marco de certificación vigente de Empresa Demo S.A. desde 2016. El certificado actual fue renovado en octubre de 2021 y tiene vigencia hasta octubre de 2024.

La organización tiene conocimiento de la publicación de la versión **ISO/IEC 27001:2022**, sin embargo, a la fecha de este informe (noviembre 2023) **no ha iniciado el proceso de transición** hacia la nueva edición. El plan de transición se encuentra pendiente de aprobación por parte del directorio.

Se prevé iniciar el análisis de brechas (gap analysis) entre la edición 2013 y la edición 2022 durante el primer semestre de 2024, con miras a completar la transición antes del vencimiento del período de transición establecido por los organismos de certificación.

4.1 Controles nuevos en ISO 27001:2022 no cubiertos en este informe

La edición 2022 introdujo 11 controles que no tienen equivalente directo en la edición 2013. Estos controles no han sido evaluados en el presente informe por encontrarse fuera del alcance del certificado vigente:

Identificación del control	Descripción	Equivalente en ISO 27001:2013
A.5.7	Inteligencia de amenazas	Sin equivalente directo
A.5.23	Seguridad en servicios en la nube	Sin equivalente directo
A.5.30	Preparación TIC para continuidad de negocio	Sin equivalente directo
A.7.4	Monitoreo de seguridad física	Sin equivalente directo
A.8.9	Gestión de configuración	Sin equivalente directo
A.8.10	Eliminación de información	Sin equivalente directo
A.8.11	Enmascaramiento de datos	Sin equivalente directo
A.8.12	Prevención de fuga de datos (DLP)	Sin equivalente directo
A.8.16	Actividades de monitoreo	Sin equivalente directo
A.8.23	Filtrado web	Sin equivalente directo
A.8.28	Codificación segura	Sin equivalente directo

Documento de prueba generado con datos sintéticos. Basado en la estructura de ISO/IEC 27001:2013 (versión obsoleta, reemplazada por ISO/IEC 27001:2022 en octubre de 2022). Empresa Demo S.A. y todos los datos son ficticios.